

device. For example, packaging can prevent access to the NFC interface. [CM135 for T131]

- i. NFC-based commissioning requires that commissioning assets are processed by the NFC powered part of the Commissionee Device. As there is potentially a higher risk for certain attacks on the NFC implementation (e.g. if devices are left unattended before completing their installation), depending on the value of the use case, the implementation SHOULD be protected against local logical and physical attacks. [CM62 for T60]
- j. For Locks and Barrier Devices that support [Standard commissioning flow](#), the QR code and power source SHALL be located on the secure side of the property. [CM280 for T260]
- k. For Locks and Barrier Devices that support [Standard commissioning flow](#), the Device documentation SHOULD include a warning to the user about the window of vulnerability upon initial power up during which the Device could be brought onto another network. [CM282 for T260]

13.6.3. Firmware

- a. Vendors of Matter implementations (including their suppliers of Matter functionality) SHOULD have a public vulnerability reporting mechanism and policy and actively monitor, identify and rectify in a timely manner security vulnerabilities throughout the publicly stated security life-cycle policy of the product. Typical responsible disclosure guidelines allow vendors from 60 to 120 days to patch a vulnerability, but the implementation of such a program is at each vendor's discretion. [CM59 for T9, T226]
- b. Devices SHOULD have a verified boot based in an immutable root of trust to verify the authenticity of firmware. Commissioners SHOULD only be loaded on a computing platform that has such a verified boot. If devices cannot support verified boot, devices SHOULD perform verification on any firmware update before applying the new firmware. [CM22 for T16, T20, T226]
- c. The private part of the code signing key (used to sign firmware) SHOULD be strongly protected against disclosure or misuse. For example, it could be stored in an HSM on a secure server outside the factory with very restricted access to only a small number of Device Manufacturer employees. [CM28 for T72]

13.6.4. Manufacturing

- a. Fusing of Devices in production SHOULD be done to limit unintended access to hardware components. For example, vendors may disable debug interfaces, and program trust anchors for secure boot. There are multiple options to secure fusing on the factory floor (e.g., physically securing the fusing station, pre-fusing the silicon, etc). [CM113 for T117]

13.6.5. Resiliency

- a. Matter implementations SHOULD implement resiliency features (e.g., responding to secure boot failures with recovery or error signaling mode) to detect and handle compromise. [CM57 for T59, T226]

13.6.6. Battery Powered Devices

- a. Battery powered Devices SHOULD respond to excessive queries by rate limiting (even limiting the rate to zero if desired). [CM51 for T52, T53]